TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

China-nexus actor uses ARTEX AI agents against more than 200 organizations

From **Cybersecurity Briefing 2026-11-04** · 2026-11-03 to 2026-11-04 (last 24 hours; Indianapolis and Indiana sections cover 2026-10-30 to 2026-11-04) · Briefing generated 2026-11-04

REPORT ID	VERSION	HANDLING
CTI-20261104-02	1.0 · 2026-11-04 10:10 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
Global	2026-11-02	2026-11-03
CVES	**ANALYST**	
CVE-2026-102489 (CVSS 8.7), CVE-2026-102490 (CVSS 8.5)	Nick Sturgeon	

NATION-STATE | HIGH | N/A | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

CrowdStrike reported on October 29, 2026 that VAPOR PANDA, a China-nexus group it has tracked since 2021, used the multi-agent ARTEX penetration-testing framework against more than 200 organizations in at least 14 countries. The activity started on October 17 and was seen over 11 days from a single ARTEX controller, which intermittently exposed the group's tooling, target files and agent transcripts. CrowdStrike confirmed post-exploitation at nine organizations and password spraying or credential scanning at 12 or more others. Named victim types include telecom providers in the U.S., Belgium and the Philippines, U.S. pharmaceutical firms, a Greek government entity, and foreign and interior ministries in Latin America and the Middle East [S1] [S2].

The agents, driven mainly by DeepSeek and a second commercial model CrowdStrike could not identify, handled reconnaissance, exploitation, web shell deployment, credential theft and retries along alternative paths. A human operator gave instructions in Chinese at key decision points. In one pharmaceutical intrusion, the operator told the agents to find Windows domain machines without the CrowdStrike Falcon sensor, and follow-on activity concentrated on those hosts. At the Greek entity, keys from a 2022 mail-server directory export were used to forge an administrator token and read mailboxes. Two government victims received the BLOODALCHEMY backdoor, for which CrowdStrike published network and file indicators [S1].

Two related incidents are often reported alongside this campaign but are not attributed to VAPOR PANDA. DIVD says ARTEX was used in its September 2026 breach, which chained two Zammad zero-days (now

CVE-2026-102489 and CVE-2026-102490, both in the CISA KEV catalog), and explicitly says other recent ARTEX attacks are not necessarily connected [S5] [S6] [S11]. WorkOS disclosed unauthorized access to an internal sales application, identified on October 30; its bulletin describes an AI-assisted offensive framework, its founder named ARTEX, and no production or application data access has been found so far [S3] [S4]. ARTEX is also used by other actors, including Storm-0940, financially motivated groups and North Korean clusters, so the tool name alone does not identify the operator [S1] [S13] [S14] [S15].

The overall risk is speed and scale rather than new tradecraft: most of the techniques exploit old keys, exposed services, weak passwords and hosts without endpoint coverage. Unknowns include the names of the victims, the initial access flaws in most intrusions and the total number of compromises, since CrowdStrike's view comes from one controller. Defenders should hunt the published indicators now, upgrade any Zammad instance to 7.2.2 or later or take it offline, close endpoint coverage gaps, rotate keys that exist in old exports and backups, and harden against password spraying [S1] [S9] [S13].

Key judgments

VERY LIKELY · HIGH CONFIDENCE
China-nexus actors will keep adopting ARTEX or similar agentic frameworks over the next 12 months, and small teams will run more simultaneous intrusions as a result. CrowdStrike and Google's threat team reach compatible conclusions from separate visibility. [S1] [S13]

LIKELY · MODERATE CONFIDENCE
More VAPOR PANDA victims will be identified beyond the nine confirmed within the next 90 days, because CrowdStrike's count reflects one controller over 11 days and more than 200 organizations were targeted. [S1] [S2]

LIKELY · MODERATE CONFIDENCE
ARTEX-branded markers such as user agents and artx-prefixed names will lose detection value within the next six months as forks and self-hosted variants change them. Behavior-based detection will matter more than string matching. [S13] [S16]

LIKELY · LOW CONFIDENCE
Operators using agentic frameworks will continue to direct agents toward hosts without endpoint sensors, so unmanaged servers and legacy Windows systems will remain preferred footholds. This rests on one documented engagement plus the logic of the technique. [S1]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
Data exposed in the WorkOS incident will be used in targeted phishing or social engineering against its customers within 60 days. WorkOS warns of this risk, but no such activity has been reported and the attacker's goal is unknown. [S3] [S4]

INDICATORS OF COMPROMISE

Indicators come from CrowdStrike (VAPOR PANDA), WorkOS's founder via BleepingComputer, DIVD, Google/Mandiant, Microsoft (Storm-0940, a separate cluster), AhnLab (no actor named) and Elastic (2023 BLOODALCHEMY samples), and each context field states which cluster it belongs to. Most were published between October 14 and November 3, 2026 and the Elastic items date from 2023, so validate network indicators before blocking; generic user agents and legitimate services are hunting pivots only, not block candidates.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`nginxmysql[.]com`	BLOODALCHEMY C2 domain, VAPOR PANDA campaign.	REPORTED		[S1]
ipv4	`45[.]153[.]126[.]223`	IP reported for nginxmysql.com, BLOODALCHEMY C2.	REPORTED		[S1]
domain	`sqlserver-sqlite[.]com`	BLOODALCHEMY C2 domain, VAPOR PANDA campaign.	REPORTED		[S1]
ipv4	`89[.]46[.]234[.]50`	IP reported for sqlserver-sqlite.com, BLOODALCHEMY C2.	REPORTED		[S1]
domain	`www[.]ddduuuppp[.]com`	BLOODALCHEMY C2 domain, VAPOR PANDA campaign.	REPORTED		[S1]
ipv4	`192[.]121[.]47[.]20`	IP reported for www.ddduuuppp.com, BLOODALCHEMY C2.	REPORTED		[S1]
sha256	`49fe70419fd19b81ca8d730a6ef7c1ec71b681d60b390761070d42686c7d2068`	Legitimate GameHook binary renamed svchost.exe and abused to sideload the loader. The source does not label the hash type; 64 hex characters match SHA-256.	REPORTED		[S1]
sha256	`3fb5a9fb3e2cb1d6208966bd4e55d10282d19c7250d827efa560463d60a12ee4`	BLOODALCHEMY loader DLL graphics-hook-filter64.dll. Hash type inferred from length.	REPORTED		[S1]
sha256	`364251838edfcf5ef1107fa692da3c5bd9a540482449f645992830134bf807ab`	BLOODALCHEMY encrypted payload graphics-hook_config.bin. Hash type inferred from length.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filename	`svchost.exe`	Name given to the GameHook binary in the BLOODALCHEMY chain. Common legitimate name: match on hash or path, never on name alone.	REPORTED		[S1]
filename	`graphics-hook-filter64.dll`	BLOODALCHEMY loader DLL sideloaded by the renamed GameHook binary.	REPORTED		[S1]
filename	`graphics-hook_config.bin`	Encrypted BLOODALCHEMY payload decrypted by the loader DLL.	REPORTED		[S1]
filepath	`D:\ProjectX\Merman_New\`	Development path found in the implant, suggesting an in-house project name. Useful for file content or YARA searches, not as an on-disk path on victims.	REPORTED		[S1]
filepath	`C:\ProgramData\artx5v\`	Directory CrowdStrike lists as an ARTEX hunting marker.	REPORTED		[S1]
command	`Command-line parameters containing artx or artex`	ARTEX hunting marker from CrowdStrike. Expect some false positives from unrelated software names.	REPORTED		[S1]
other	`Cloud roles with names prefixed artx`	ARTEX hunting marker: review cloud IAM roles and role creation events.	REPORTED		[S1]
other	`Administration-command comments prefixed art18-`	ARTEX hunting marker: search cloud administration command history and audit logs.	REPORTED		[S1]
user-agent	`artex-enrich/1.0`	Seen in threat actor web requests in the WorkOS incident per its founder. AhnLab found it in source code only and did not observe it in its test; the string can be changed or absent.	REPORTED		[S3] [S16]
user-agent	`norma/0.4`	Seen in threat actor web requests in the WorkOS incident per its founder, and observed by AhnLab when ARTEX accessed a target web page in a test.	REPORTED		[S3] [S16]
user-agent	`artex-selfupdate`	ARTEX update check to GitHub per AhnLab. Would appear in egress logs from an operator host, not in target web logs.	REPORTED		[S16]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
user-agent	`Mozilla/5.0 (Spa-api-recon)`	From an api-recon reference script in ARTEX per AhnLab. Not observed in its test because the script was not run.	REPORTED		[S16]
user-agent	`Mozilla/5.0 (Spa-api-recon spider)`	From an api-recon reference script in ARTEX per AhnLab. Not observed in its test.	REPORTED		[S16]
user-agent	`curl/<VERSION>`	File upload activity in AhnLab's ARTEX test. Generic and widely used legitimately: context only.	REPORTED		[S16]
other	`artex-i13033`	Non-expiring admin API token created for persistence in the DIVD intrusion (Zammad context). Not linked to VAPOR PANDA. Numbering is job-specific, so also search for the artex-i prefix.	REPORTED	2026-09-21	[S5]
other	`ARTEX_i13444_CVE2019`	Label on a test of a 2019 mail server vulnerability in the DIVD intrusion logs. The CVE itself is not specified.	REPORTED	2026-09-21	[S5]
other	`Agent-written script comments such as "no phishing" and "no spam"`	Behavioral artifact from the DIVD incident as summarized by Sysdig. Weak on its own.	REPORTED	2026-09-21	[S17]
domain	`webhook[.]site`	Legitimate service abused with 491 rotating URLs for C2 and result exfiltration in ARTEX cases handled by Mandiant. Do not treat as malicious by itself; alert on server-originated traffic.	REPORTED		[S13]
filename	`cl1217.jsp`	Web shell name in Mandiant ARTEX cases. Not linked to VAPOR PANDA.	REPORTED		[S13]
filename	`f1219a.jsp`	Web shell name in Mandiant ARTEX cases. Not linked to VAPOR PANDA.	REPORTED		[S13]
filename	`z1219.jsp`	Web shell name in Mandiant ARTEX cases. Not linked to VAPOR PANDA.	REPORTED		[S13]
filename	`artex-probe-*`	Probe file pattern with five-digit incrementing numbers in Mandiant ARTEX cases.	REPORTED		[S13]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`ArtexProbe`	String in account names created in Mandiant ARTEX cases. Incremental numeric markers also appeared in account names, passwords, dropped files and email subjects.	REPORTED		[S13]
other	`script too large`	Error string seen when the framework retried deployment in Mandiant ARTEX cases. Search web and application logs; weak alone.	REPORTED		[S13]
other	`variable 't is already defined`	Error string in Mandiant ARTEX cases, likely tied to scripts being rewritten by sub-agents. Weak alone.	REPORTED		[S13]
ipv4	`144[.]172[.]64[.]128`	Storm-0940 infrastructure per Microsoft. CrowdStrike says this activity is separate from VAPOR PANDA.	REPORTED		[S14]
ipv4	`144[.]172[.]64[.]99`	Storm-0940 infrastructure per Microsoft. Separate from VAPOR PANDA.	REPORTED		[S14]
ipv4	`144[.]172[.]64[.]60`	Storm-0940 infrastructure per Microsoft. Separate from VAPOR PANDA.	REPORTED		[S14]
ipv4	`187[.]15[.]88[.]186`	Transient VPN address tied to Storm-0940 activity, relevant to October 15-16 only. Likely to go stale; use for historical log review.	REPORTED	2026-10-15	[S14]
ipv4	`187[.]15[.]90[.]217`	Transient VPN address tied to Storm-0940 activity, relevant to October 15-16 only. Historical review.	REPORTED	2026-10-15	[S14]
ipv4	`187[.]15[.]89[.]186`	Transient VPN address tied to Storm-0940 activity, relevant to October 15-16 only. Historical review.	REPORTED	2026-10-15	[S14]
user-agent	`Python-urllib/3.12`	Generic user agent in Microsoft's Storm-0940 indicators. Pair with application ID or source IP; not a standalone signal.	REPORTED		[S14]
user-agent	`python-requests/2.31.0`	Generic user agent in Microsoft's Storm-0940 indicators. Not a standalone signal.	REPORTED		[S14]
user-agent	`python-requests/2.34.2`	Generic user agent in Microsoft's Storm-0940 indicators. Not a standalone signal.	REPORTED		[S14]
user-agent	`curl/7.88.1`	Generic user agent in Microsoft's Storm-0940 indicators. Not a standalone signal.	REPORTED		[S14]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
user-agent	`azure-toolkit/1.0`	User agent in Microsoft's Storm-0940 indicators. Review in context.	REPORTED		[S14]
other	`506e08f9-6e9a-4da4-942b-a099a03644ae`	Entra application ID for ConnectWise Cloud Backup used in Microsoft's Storm-0940 hunting. A legitimate application, not malicious in itself. Microsoft mentions four IDs but shows three on the page we read.	REPORTED		[S14]
other	`24205314-2b89-4e07-a2a4-579e898a5640`	Entra application ID for ConnectWise - MS Teams in Microsoft's hunting. A legitimate application; review its activity.	REPORTED		[S14]
other	`0de14c77-b9b0-4137-9360-34878a929827`	Entra application ID for ConnectWise - MS Graph in Microsoft's hunting. A legitimate application; review its activity.	REPORTED		[S14]
ipv4	`134[.]122[.]137[.]132`	AhnLab IoC tied to exposed operational directories in its ARTEX analysis. Role not stated and no actor or campaign linked.	REPORTED		[S16]
ipv4	`204[.]194[.]51[.]54`	AhnLab IoC tied to exposed operational directories in its ARTEX analysis. Role not stated and no actor or campaign linked.	REPORTED		[S16]
md5	`085f53a1ce8c634ac7b0d63e42b56b15`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`0c501aca4fc29efe47f122ddc9c1af85`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`0eb2590676e565221109a3ee988e1faa3`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`220a1465b2c5ee3ec86861ee17a91e2f`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`2d13374c14bcaaa99ab00f16cc18b300`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
md5	`326bb512422930f723e8434d219bea15`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`4fff3a0e67210deea726a3bd8c0b625f`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`5881f74d3bb167e48f6e61c8d9c220e7`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`5a38c92fcf2772f65517485f3a23810e`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`5d151bb4512fc48932a83d3bc24ea806`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`6593d2601f967566ae1efe521ec7b470`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`773dc8997a50425fb4146161d747c10f`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`78c3efc26c8db056933da58032361706`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`8858508e75ac58ce586631101be87973`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`912e8bb04a86f34c76d7d9bad8b67685`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`baddd4d75a6980e0df8d47333d9472c3`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
md5	`be4033d98dd65437516a94048adc8ac5`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
md5	`fec5d7eb6cf4ed6cfbcd2c588bb761af`	AhnLab: file from exposed ARTEX-related operational directories. Not mapped to a file name or actor.	REPORTED		[S16]
port	`61616/tcp`	ActiveMQ OpenWire port used for initial access in AhnLab's ARTEX test (CVE-2023-46604). A test scenario, not a campaign indicator; a reminder that ARTEX picks entry points from discovered services.	REPORTED		[S16]
sha256	`e14ee3e2ce0010110c409f119d56f6151fdca64e20d902412db46406ed89009a`	BrLogAPI.dll, BLOODALCHEMY loader from Elastic's 2023 analysis. Older variant, different from the VAPOR PANDA chain.	REPORTED		[S18]
sha256	`25268bc07b64d0d1df441eb6f4b40dc44a6af568be0657533088d3bfd2a05455`	BLOODALCHEMY payload from Elastic's 2023 analysis. Older variant.	REPORTED		[S18]
filename	`BrLogAPI.dll`	DLL name sideloaded in the 2023 BLOODALCHEMY chain. It shares a name with a legitimate Brother DLL: confirm by hash.	REPORTED		[S18]
filename	`BrDifxapi.exe`	Host binary with a revoked Brother signature in the 2023 BLOODALCHEMY chain. Legitimate file name: confirm by signature and path.	REPORTED		[S18]
filepath	`\Test\test.exe`	2023 BLOODALCHEMY persistence path suffix under %ProgramFiles%, %ProgramFiles(x86)%, %Appdata% or %LocalAppData%\Programs, depending on privilege.	REPORTED		[S18]
other	`Windows service named Test with description Digital Imaging System`	2023 BLOODALCHEMY persistence. May have changed in current variants.	REPORTED		[S18]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`/Inform/logger/`	HTTP URI used by BLOODALCHEMY C2 in the 2023 analysis. Not confirmed for the VAPOR PANDA C2 servers.	REPORTED		[S18]
other	`Setuid-family calls, root-owned child processes or writes to privileged paths by the zammad user`	Behavior to watch for exploitation of CVE-2026-102490, including Zammad application processes launching shells or downloading tools.	REPORTED		[S8] [S17]
ipv4	`169[.]254[.]169[.]254`	Standard cloud Instance Metadata Service address. CrowdStrike describes XXE used to query the metadata service, so a web application reaching this address is suspicious. Benign in many workloads: compare with baseline.	DERIVED		[S1]
domain	`*[.]scm[.]azurewebsites[.]net`	Standard host pattern for Azure App Service Kudu/SCM. Google reports abuse of Kudu administrative APIs in ARTEX cases, so unexpected source IPs against these hosts deserve review. Legitimate Microsoft service; not from the VAPOR PANDA reporting.	DERIVED		[S13]
other	`Unusual reads of ms-Mcs-AdmPwd or msLAPS-Password AD attributes`	These attributes store LAPS passwords, and CrowdStrike reports LAPS reads. Audit through Windows Event 4662 with attribute auditing enabled.	DERIVED		[S1]
other	`Changes to msDS-AllowedToActOnBehalfOfOtherIdentity`	This AD attribute controls resource-based constrained delegation, which CrowdStrike reports abused for impersonation. Audit through Windows Event 5136.	DERIVED		[S1]
other	`svchost.exe running outside %SystemRoot%\System32`	The renamed GameHook binary is not the Windows service host, so it should run from another path. The real staged path is not published; this is inferred from the described chain.	DERIVED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filename	`chisel / chisel.exe`	Default binary name for the Chisel tunneling tool named by CrowdStrike. The actor's actual file names are not published and could differ.	DERIVED		[S1]
filename	`vpnbridge.exe / vpnclient.exe / vpnserver.exe`	Default SoftEther VPN binary names; CrowdStrike names SoftEther for tunneling. The actor's actual file names are not published and could differ.	DERIVED		[S1]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

An operator gives ARTEX a target list and objectives. A main agent coordinates planner and worker agents that share a graph of facts, findings and goals, working from initial access through host reconnaissance to lateral movement and trying other paths in parallel when one fails. Initial access in the VAPOR PANDA campaign included an unsigned SAML assertion chained with an XXE flaw, exposed services, and stolen or leaked keys and VPN configuration. Agents then planted JSP and PHP web shells, read LAPS passwords, abused resource-based constrained delegation, forged tokens and read mailboxes, and tunneled with Chisel and SoftEther over Tor, SOCKS proxies and a compromised relay. On government targets the group deployed BLOODALCHEMY through a renamed GameHook binary that sideloads a loader DLL. The operator intervenes at decision points, and activity tends to be fast and noisy: DIVD logged more than 450,000 requests and 2,500 scripts in its own, separately attributed incident, and the attacker went from initial access to root in 12 minutes [S1] [S5] [S13].

Threat actor

VAPOR PANDA

Attribution confidence: Moderate · **Motivation:** Cyber espionage, based on government, think tank, energy and extractive targeting since 2021 and the 2026 expansion to pharmaceutical, semiconductor, nuclear and defense targets. · **Suspected origin:** China-nexus per CrowdStrike. The post read for this report does not tie the group to a named government body.

Attribution rests on one vendor: CrowdStrike Intelligence linked the ARTEX controller to VAPOR PANDA infrastructure and gives no formal confidence rating. CrowdStrike says this is separate from Storm-0940 activity, which Microsoft and Google report and Google overlaps with UNC7228. No source links WorkOS or DIVD to VAPOR PANDA. This is the group's first observed use of AI-driven intrusion tooling according to CrowdStrike [S1] [S13] [S14].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Resource Development	T1588.007 Obtain Capabilities: Artificial Intelligence	Used the ARTEX framework with DeepSeek and a second, unidentified commercial model to plan and execute intrusions. [S1]	Not directly visible to victims; look for high-speed, retry-heavy automated activity across telemetry.
Initial Access	T1190 Exploit Public-Facing Application	Chained an unsigned SAML assertion with an XXE flaw at a U.S. pharmaceutical organization; abused an exposed unauthenticated orchestration service at another. [S1]	Review web logs for XML payloads with external entities and SAML responses without valid signatures; inventory exposed orchestration services.
Initial Access	T1078 Valid Accounts	Used stolen VPN configurations and leaked credentials, including a VPN client key from a May 2024 email leak. [S1]	Flag VPN and account logins from new ASNs or hosting providers, especially for dormant keys.
Initial Access	T1133 External Remote Services	Connected over VPN to reach internal networks using recovered configurations. [S1]	Compare VPN sessions with user, device and geography baselines; alert on reused client certificates or keys.
Execution	T1651 Cloud Administration Command	Used a cloud role to issue administrative commands to thousands of instances through a cloud systems manager. [S1]	Alert on bulk cloud run-command activity and comments starting with art18-.
Persistence	T1505.003 Server Software Component: Web Shell	Agents wrote JSP and PHP web shells; the operator directly instructed this in some cases. [S1]	Monitor file creation in web roots and web server processes spawning shells.

Tactic	Technique	Procedure observed	Detection opportunity
Privilege Escalation	T1134.001 Access Token Manipulation: Token Impersonation/Theft	Abused resource-based constrained delegation to impersonate a privileged account. [S1]	Audit writes to msDS-AllowedToActOnBehalfOfOtherIdentity (Event 5136) and unusual S4U ticket requests.
Privilege Escalation	T1068 Exploitation for Privilege Escalation	In the DIVD incident, not attributed to VAPOR PANDA, CVE-2026-102490 raised access from the zammad account to root in about a minute. [S5] [S8] [S17]	Watch setuid-family calls and root-owned child processes from the zammad service account on packaged installs.
Defense Evasion	T1574.001 Hijack Execution Flow: DLL	Renamed GameHook binary sideloads graphics-hook-filter64.dll, which decrypts graphics-hook_config.bin. [S1]	Hunt image loads of the DLL and the published hashes.
Defense Evasion	T1036.005 Masquerading: Match Legitimate Resource Name or Location	GameHook binary renamed svchost.exe. [S1]	Alert on svchost.exe outside System32 or with an unexpected parent.
Credential Access	T1552.005 Unsecured Credentials: Cloud Instance Metadata API	Queried the metadata service via XXE to obtain a powerful cloud role. [S1]	Require IMDSv2 and alert on metadata role credentials used from outside the instance.
Credential Access	T1555 Credentials from Password Stores	Read LAPS passwords from Active Directory. [S1]	Audit reads of LAPS attributes (Event 4662) and compare to authorized admin identities.
Credential Access	T1606.002 Forge Web Credentials: SAML Tokens	Used unsigned SAML assertions to authenticate. [S1]	Test that service providers reject unsigned assertions; review logins with no matching identity provider event.
Credential Access	T1606 Forge Web Credentials	Forged a mail server admin token at a Greek government entity using keys from a 2022 directory export. [S1] [S2]	Look for admin sessions with no matching login event; rotate keys and validate token issuance logs.

Tactic	Technique	Procedure observed	Detection opportunity
Credential Access	T1110.003 Brute Force: Password Spraying	Sprayed government, think tank and corporate accounts, with credential scanning at 12 or more organizations. [S1]	Alert on many distinct accounts failing from one source in a short window.
Credential Access	T1558.003 Steal or Forge Kerberos Tickets: Kerberoasting	Observed in Mandiant ARTEX cases, not stated for VAPOR PANDA. [S13]	Watch for bursts of service ticket requests with RC4 (Event 4769).
Credential Access	T1003.006 OS Credential Dumping: DCSync	DCSync-style credential theft observed in Mandiant ARTEX cases, not stated for VAPOR PANDA. [S13]	Alert on directory replication requests from non-domain-controller accounts or hosts.
Discovery	T1518.001 Software Discovery: Security Software Discovery	Agents checked process lists and folder listings to find Windows hosts without the Falcon sensor. [S1]	Watch for scripted tasklist and directory checks for EDR paths across multiple hosts in short periods.
Discovery	T1046 Network Service Discovery	Network scanning after compromise at the nine confirmed organizations. [S1] [S13]	Flag internet-facing or server hosts starting LDAP, SMB, Kerberos or remote-admin connections.
Collection	T1114.002 Email Collection: Remote Email Collection	Read mailboxes on the compromised mail server and recovered VPN configurations from sent mail. [S1]	Review mailbox access by admin tokens and application identities; alert on bulk reads.
Command and Control	T1090.003 Proxy: Multi-hop Proxy	Routed traffic over Tor, SOCKS proxies and a compromised relay. [S1]	Block or alert on Tor exit traffic and new outbound proxies from servers.
Command and Control	T1572 Protocol Tunneling	Tunneled with Chisel and SoftEther. [S1]	Hunt for the tool binaries and long-lived outbound connections from servers to unknown hosts.

Tactic	Technique	Procedure observed	Detection opportunity
Exfiltration	T1567.004 Exfiltration Over Web Service: Exfiltration Over Webhook	Mandiant ARTEX cases posted command results to rotating webhook.site URLs; not stated for VAPOR PANDA. [S13]	Alert on servers contacting webhook and out-of-band testing services they have no business need to use.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

BLOODALCHEMY loader DLL load from the VAPOR PANDA chain `SIGMA`

```
title: BLOODALCHEMY Loader DLL Load (VAPOR PANDA chain)
status: experimental
logsource:
  category: image_load
  product: windows
detection:
  selection_name:
    ImageLoaded|endswith: '\graphics-hook-filter64.dll'
  selection_hash:
    Hashes|contains: 'SHA256=3FB5A9FB3E2CB1D6208966BD4E55D10282D19C7250D827EFA560463D60A12EE4'
  condition: 1 of selection_*
level: high
```

Requires Sysmon Event ID 7 or an EDR equivalent. Hash field format varies by logging tool. Built from CrowdStrike's reported chain [S1].

ARTEX hunting markers in process and file activity `KQL`

```
let markers = @"(?i)(artx5v|art18-|artex-probe-|artexprobe|\bartx\b|\bartex\b)";
union
  (DeviceProcessEvents | where Timestamp > ago(30d) | where ProcessCommandLine matches regex markers |
project Timestamp, DeviceName, AccountName, FileName, Evidence = ProcessCommandLine),
  (DeviceFileEvents | where Timestamp > ago(30d) | where FolderPath matches regex markers | project
Timestamp, DeviceName, AccountName = InitiatingProcessAccountName, FileName, Evidence = FolderPath)
| order by Timestamp desc
```

Microsoft Defender schema. Combines CrowdStrike and Google/Mandiant markers [S1] [S13]. Hosts without a sensor return nothing, so absence of results is not assurance; treat matches as leads because of possible unrelated software names.

ARTEX-associated user agents inbound to web applications `SURICATA`

```
alert http any any -> $HOME_NET any (msg:"HUNT ARTEX-associated user agent norma/0.4";
flow:established,to_server; http.user_agent; content:"norma/0.4"; nocase; classtype:trojan-activity;
sid:9100001; rev:1;)
alert http any any -> $HOME_NET any (msg:"HUNT ARTEX-associated user agent artex-enrich/1.0";
flow:established,to_server; http.user_agent; content:"artex-enrich/1.0"; nocase; classtype:trojan-
activity; sid:9100002; rev:1;)
```

Low assurance: the strings can be changed or absent [S3] [S16]. Requires TLS inspection for HTTPS traffic; the same strings can be searched in web server and proxy logs. Replace sids with your local range.

Password spray from one source against Windows logons `SPLUNK SPL`

```
index=wineventlog EventCode=4625 earliest=-24h
| bin _time span=10m
| stats dc(user) AS distinct_users count AS failures values(host) AS hosts BY _time src_ip
| where distinct_users >= 25
| sort - distinct_users
```

Field names depend on your add-on; tune the threshold to your baseline. Add the equivalent for cloud identity sign-in logs, since CrowdStrike and Microsoft both report spraying and low-and-slow spraying may require a longer window [S1] [S14].

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Internet-facing applications, identity and cloud services (VAPOR PANDA campaign)	No product or CVE named. Reported weaknesses: unsigned SAML assertions, XXE, unauthenticated orchestration services, unrotated keys, unprotected hosts	Configuration and key hygiene; see steps below	None named	N/A	N/A	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Zammad (DIVD incident, not attributed to VAPOR PANDA)	6.3.0 through 6.5.4 exploitable. 7.0.0 through 7.1.2 contain the bug but it is not exploitable there per the CVE record; DIVD lists through 7.1.3. Status before 6.3.0 unknown	Upgrade to supported 7.x; Zammad added hardening in 7.2.0. Use 7.2.2 or later to cover both flaws	CVE-2026-102489	8.7 (CVSS 4.0); 9.4 when chained	0.2248 (97.7th percentile, 2026-11-04)	Yes (added 2026-10-02)	2026-10-05
Zammad DEB and RPM packages (DIVD incident, not attributed to VAPOR PANDA)	Packaged versions 1.5.0 up to, not including, 7.2.2. Source installs and official containers are not affected	7.2.2	CVE-2026-102490	8.5 (CVSS 4.0); 9.4 when chained	0.1094 (95.9th percentile, 2026-11-04)	Yes (added 2026-10-02)	2026-10-05

Immediate (0–24 hours)

- Search DNS, proxy, firewall and EDR data for the VAPOR PANDA domains, IPs and hashes, using the longest retention available and at least from October 17, 2026. Validate network indicators, then block. `SOC` [S1]
- Hunt for ARTEX markers: artx or artex in command lines, artx-prefixed cloud roles, art18- command comments, C:\ProgramData\artx5v\, artex-probe-* files and ArtexProbe accounts. `SOC` [S1] [S13]
- List all Windows hosts and servers without a working EDR sensor, including those believed unreachable from the internet, and prioritize deployment on any that hold credentials or internet exposure. `IT OPS` [S1]
- Find any Zammad instances. Preserve /var/log/zammad and /var/log/nginx, run DIVD's published log check, then upgrade to 7.2.2 or later or take the instance offline. Treat any 6.3.0 to 6.5.4 instance that was internet-facing as possibly compromised. `IT OPS` [S6] [S9] [S17]
- If your organization uses ConnectWise applications affected by the Storm-0940 incident, check for the vendor's current restoration guidance, keep affected connections disabled until told otherwise, search tenants by application ID and preserve logs before removing anything. `IT OPS` [S14]
- If you are a WorkOS customer, watch for direct notice from WorkOS and warn sales, support and identity administrators to verify unexpected requests, even those that cite real people or past support conversations. `SOC` [S3] [S4]

Short term (1–7 days)

- Rotate signing keys, preauthentication keys and service credentials after any suspected exposure, including keys that exist in old backups and directory exports. Search file shares and backups for such exports. `IT OPS` [S1]

- Harden against spraying: require phishing-resistant MFA for administrators, MFA for all remote access, disable legacy authentication, and review lockout and rate-limit settings. `IT OPS` [S1] [S13]
- Enforce SAML signature validation, require IMDSv2, and limit cloud role command-execution rights to the minimum set of instances. `IT OPS` [S1]
- Search mailboxes and file stores for VPN profiles and client keys. Rotate any found, along with any keys known to be in past leaks. `IT OPS` [S1]
- Audit who can read LAPS passwords and who can write delegation attributes in Active Directory, and enable auditing for those objects. `IT OPS` [S1]
- Patch internet-facing appliances, particularly long-lived Linux servers, and keep firmware current. `IT OPS` [S1] [S16]
- Review response timelines against intrusions measured in minutes to hours, and confirm who can authorize host isolation and account disablement after hours. `LEADERSHIP` [S5] [S13]

Long term

- Replace long-lived secrets with short-lived, workload-bound credentials such as managed identities and workload identity federation, and scan continuously for exposed secrets. `IT OPS` [S13]
- Fund and require full EDR coverage as a standing measure, tracked as a metric reported to leadership and contractually for managed clients where possible. `LEADERSHIP` [S1] [S16]
- Build detections on sequences across identity, cloud control plane, endpoint and network logs rather than single strings, and retain logs long enough to set baselines. `SOC` [S13] [S16]
- Harden Active Directory: secure AD CS templates, enable Credential Guard, enforce SMB and LDAP signing, and reduce NTLM. `IT OPS` [S13]
- Review internal tools that hold customer communications or CRM data, since the WorkOS case shows these can expose sensitive context even without production access. Limit external reach and apply least privilege. `LEADERSHIP` [S4]

Workarounds & compensating controls

- Limit server egress and alert on connections from servers to webhook services, tunneling platforms, file-sharing services and AI platforms they do not need. `SOC` [S13]
- Segment helpdesk and DMZ systems so a single compromised server cannot reach internal services. DIVD credits segmentation and response with stopping deeper movement. `IT OPS` [S13] [S17]
- If a Zammad upgrade must wait, keep it off the internet and restrict access to the underlying server to trusted administrators only. `IT OPS` [S6] [S10]
- Restrict admin APIs, consoles and CI/CD systems to trusted networks, and apply rate and recipient limits to high-impact business APIs such as email and user management. `IT OPS` [S13]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] CrowdStrike Counter Adversary Operations: VAPOR PANDA uses ARTEX to scale global campaign
Published 2026-10-29 · **A2** Completely reliable, probably true
Primary source for the campaign and its indicators. Campaign details are single-vendor, though others independently report ARTEX abuse.

[S2] BleepingComputer: Chinese hackers use ARTEX AI in automated attacks against 200 orgs
Published 2026-11-02 · **B2** Usually reliable, probably true
Briefing source; secondary summary of CrowdStrike and DIVD.

[S3] BleepingComputer: WorkOS says attacker used ARTEX AI to breach internal sales app
Published 2026-11-03 · **B2** Usually reliable, probably true
Briefing source; carries the founder's statements on ARTEX and user agents. His X posts could not be opened directly.

[S4] WorkOS: October 30, 2026 Data Security Incident
Published 2026-11-02 · **A2** Completely reliable, probably true
Victim's own bulletin; investigation ongoing.

[S5] DIVD: LinkedIn post introducing ARTEX as the framework in DIVD's incident
Published · **A2** Completely reliable, probably true
Victim's direct statement. The page shows only a relative timestamp, so the exact date is unknown; it predates the November 2 BleepingComputer article.

[S6] DIVD CSIRT: DIVD-2026-00015: Zammad Vulnerabilities
Published 2026-10-01 · **A2** Completely reliable, probably true
Date is last modified. The page predates the 7.2.2 fix, so its version and fix details are out of date.

[S7] CVE Program: CVE-2026-102489
Published 2026-09-30 · **A1** Completely reliable, confirmed by other sources
CVE record assigned by DIVD; updated 2026-10-19.

[S8] CVE Program: CVE-2026-102490
Published 2026-09-30 · **A1** Completely reliable, confirmed by other sources
CVE record assigned by DIVD; updated 2026-10-08.

[S9] Zammad (GitHub): Security advisory GHSA-p97w-927q-8vxq
Published 2026-10-08 · **A1** Completely reliable, confirmed by other sources
Vendor advisory naming 7.2.2 as the fix for CVE-2026-102490.

[S10] Zammad: Advisory on CVE-2026-102489 and CVE-2026-102490
Published 2026-10-05 · **A2** Completely reliable, probably true
Vendor statement. The text read still showed the LPE fix as pending, superseded by S9. Disputes DIVD's disclosure timing.

[S11] CISA: Known Exploited Vulnerabilities catalog, version 2026.11.03
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Confirms both Zammad CVEs with due date 2026-10-05.

[S12] FIRST: EPSS API results for CVE-2026-102489 and CVE-2026-102490
Published 2026-11-04 · **A2** Completely reliable, probably true
Model output, so a probability rather than an observation.

[S13] Google Threat Intelligence Group / Mandiant: ARTEX and Friends: Enter Agentic Offensive Frameworks
Published 2026-10-30 · **A2** Completely reliable, probably true
Independent technical view from incident response cases, not specific to VAPOR PANDA.

[S14] Microsoft Security Blog: AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise
Published 2026-10-21 · **A2** Completely reliable, probably true
Storm-0940 and ConnectWise; a separate cluster per CrowdStrike.

[S15] Microsoft Security Blog: Tracking AI adoption in North Korean threat actor tradecraft
Published 2026-10-29 · **A2** Completely reliable, probably true
Reports ARTEX use by Onyx Sleet and Pearl Sleet since late October 2026.

[S16] AhnLab ASEC: The Threat of AI-Driven Autonomous Penetration Testing, as Examined by ARTEX
Published 2026-10-14 · **A2** Completely reliable, probably true
Hands-on testing of ARTEX and IoCs from exposed directories; no actor named.

[S17] Sysdig: AI agent exploits Zammad zero-days in DIVD breach: what we know and how to detect it
Published 2026-10-05 · **B3** Usually reliable, possibly true
Japanese translation of an October 2 post. Secondary summary plus vendor detection guidance.

[S18] Elastic Security Labs: Disclosing the BLOODALCHEMY backdoor
Published 2023-10-13 · **A2** Completely reliable, probably true
Original malware write-up; indicators are three years old and describe an earlier chain.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2023-10-13	Elastic publishes its analysis of the BLOODALCHEMY backdoor.	[S18]
2026-08	Google reports threat actor use of ARTEX in incident response cases since late August (no exact day given).	[S13]
2026-09-21	DIVD is breached through Zammad zero-days; detected September 22.	[S6] [S17]
2026-09-30	CVE records for both Zammad flaws are published.	[S7] [S8]
2026-10-02	CISA adds both Zammad CVEs to KEV.	[S11]
2026-10-08	Zammad publishes an advisory naming 7.2.2 as the fix for CVE-2026-102490.	[S9]
2026-10-14	AhnLab publishes its ARTEX testing and indicators.	[S16]
2026-10-17	VAPOR PANDA campaign starts per CrowdStrike; 11 days of activity observed from one controller.	[S1]
2026-10-21	Microsoft reports Storm-0940 use of ARTEX and the ConnectWise supply chain compromise.	[S14]
2026-10-29	CrowdStrike publishes the VAPOR PANDA report. Microsoft reports ARTEX use by North Korean groups the same day.	[S1] [S15]
2026-10-30	WorkOS identifies unauthorized access to its internal sales application. Google publishes its agentic framework analysis.	[S4] [S13]
2026-11-02	WorkOS bulletin is dated. BleepingComputer covers the VAPOR PANDA report.	[S2] [S4]
2026-11-03	BleepingComputer reports the WorkOS breach, with the founder's statements naming ARTEX.	[S3]

Relevance to Indianapolis, Indiana & managed clients

No source names an Indianapolis or Indiana victim, and this report found no evidence of one. Exposure is still plausible. CrowdStrike's U.S. targeting covered pharmaceutical, semiconductor, defense, nuclear and financial organizations, along with telecom providers, and Indiana has major life sciences, advanced manufacturing and defense supply chain employers [S1]. State and local government, healthcare and education are not named as

targets in this campaign, but they often have the same weaknesses the agents exploited: old service keys, exposed legacy applications, password-only remote access and servers without EDR. Small and mid-size businesses are unlikely to be chosen by an espionage actor unless they supply larger targets, but cheap, widely available forks lower the bar for financially motivated crews, whom Google already sees using these tools [S13]. For managed IT service clients, the most direct points are the Storm-0940 compromise of a multi-tenant ConnectWise application, which Microsoft reports reached customer environments [S14], and sensor coverage: unmanaged client servers are exactly what the operator asked agents to find [S1]. Service providers should confirm RMM, backup and application permissions, and report EDR gaps to clients. Self-hosted helpdesk systems such as Zammad deserve a specific check, as they hold credentials and sensitive client tickets [S5] [S9].

Intelligence gaps

- CrowdStrike does not name its victims or all 14 countries. The total number of compromises is unknown because its view is limited to one controller and to its own telemetry.
- Initial access details are not published for most of the nine intrusions, and no CVEs are named for the VAPOR PANDA campaign. The SAML, XXE and orchestration products are not identified.
- The second commercial LLM is unidentified, and the sources read do not say how the accounts were obtained or whether they were disabled.
- It is unknown how WorkOS's attacker got in, who it was, how many customers are affected and whether the data has been used. Its investigation is ongoing and a fuller account has been promised.
- DIVD has promised a redacted public research repository. Watch for fresh ARTEX indicators there, and for whether ARTEX or a human found the Zammad zero-day, which remains unresolved.
- It is unclear whether ARTEX forks such as ScopeWeaver or ARTEX PRO keep the same user agents and naming markers.
- The relationship between VAPOR PANDA, Storm-0940 and UNC7228 has not been reconciled across vendors beyond CrowdStrike's statement of separation and Google's overlap of UNC7228 with Storm-0940.

Other notes

- Correction to the briefing excerpt: CVEs are now assigned to the Zammad flaws in the DIVD incident (CVE-2026-102489 and CVE-2026-102490). They are listed in this report because of the excerpt's reference, but they are not tied to the VAPOR PANDA campaign [S5] [S7] [S8].
- Framing caution: the excerpt can be read as CrowdStrike and DIVD describing the same campaign. They do not. DIVD says other recent ARTEX attacks are not necessarily connected to its own, and the BleepingComputer article does not explicitly link them [S2] [S5].
- Date differences: the campaign report was published October 29, while the briefing's published date reflects BleepingComputer's November 2 article. The WorkOS bulletin is dated November 2, while the excerpt gives November 3, the date of press coverage [S1] [S2] [S3] [S4].
- Source disagreement: the BleepingComputer WorkOS article as read dates the DIVD attack to September 2025. DIVD and all other sources show September 2026, so this appears to be an error [S3] [S6]. BleepingComputer's list of WorkOS data also omits phone numbers, which the WorkOS bulletin includes [S3] [S4], and its campaign article names telecom victims only in the U.S. and Belgium, while CrowdStrike adds the Philippines [S1] [S2].

- WorkOS's bulletin describes an AI-assisted offensive framework without naming ARTEX in the text read; the name comes from founder Michael Grinich through BleepingComputer, and from link URLs in the bulletin. AhnLab warns that user agents are weak evidence [S3] [S4] [S16].
- Repository status is described differently: BleepingComputer says the project went private or proprietary, while Google says the creator, GitHub user Autumn-27, removed the original repository in October 2026 because of abuse. Both agree forks remain in circulation [S2] [S3] [S13].
- Zammad version sources differ. The DIVD case page is older and lists CVE-2026-102490 through 7.1.0-alpha, while the CVE record and GitHub advisory show packaged versions up to 7.2.1 affected with 7.2.2 fixed. Those newer records are used here [S6] [S8] [S9]. DIVD and Zammad also differ on disclosure timing: DIVD records reporting to Zammad on September 24, while Zammad says it first received a report about CVE-2026-102489 in August and that CVE-2026-102490 details became public before it had what it needed [S6] [S10].
- Other ARTEX users: Microsoft reports Onyx Sleet and Pearl Sleet using ARTEX since late October 2026 and says AI-enabled operations remain human-directed. Google also names related frameworks including PentAGI, CAIRN and Hexstrike [S13] [S15].
- CrowdStrike says the operator used the PRC red-team slang term 猎鹰 for the Falcon sensor. This appears in exposed operator transcripts and is not a host or network indicator [S1].
- Handling note: the BLOODALCHEMY C2 domains are defanged in any free-text reuse, for example nginxmysql[.]com. Detection queries have not been tested in a production environment.

CTI-20261104-02 v1.0 · Generated 2026-11-04 10:10 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.